

FPConnect - Auditoria de Seguranca

Gerado em 05/04/2026 02:13:15

Relatorio de Vulnerabilidades e Correcoes

Data: 2026-04-05

Projeto: FPConnect RCA Copilot

Escopo: backend API, aplicacao web Next.js e aplicacao mobile Expo/React Native

Resumo executivo

Foi realizada uma revisao tecnica do sistema com foco em autenticao, autorizacao, exposicao de rotas, configuracao insegura, dependencias vulneraveis e canais de exportacao de dados.

As vulnerabilidades de maior risco identificadas estavam concentradas no backend e no frontend web:

1. CORS aberto com credenciais e politicas excessivamente permissivas.
2. Segredo JWT inseguro por padrao e sem validacao forte em producao.
3. Cadastro publico permitindo elevacao de privilegio por meio do campo `role`.
4. Endpoints do agente de IA expostos sem autenticao.
5. Endpoint de ingestao de Intel acessivel sem autenticao obrigatoria.
6. Comparacao simples de chave interna do n8n, sem comparacao em tempo constante.
7. Respostas de erro do endpoint de narracao expondo detalhes internos do provider.
8. Uso de dependencias JavaScript com advisories conhecidas no web e mobile.
9. Exportacao para planilha via `xlsx`, biblioteca com historico de advisories e sem necessidade funcional obrigatoria no projeto.
10. Cliente mobile aceitando URL remota insegura sem qualquer endurecimento minimo.

Vulnerabilidades encontradas e resolvidas

Backend

1. CORS permissivo demais.
 - Antes: `allow\_origins=["\*"]`, `allow\_credentials=True`, metodos e headers liberados genericamente.
 - Correcao: CORS passou a ser configuravel por ambiente, sem wildcard e sem credenciais abertas.
2. Segredo padrao inseguro.
 - Antes: `SECRET\_KEY` aceitava valor default fraco.
 - Correcao: adicionado fail-fast para producao exigindo segredo unico com pelo menos 32 caracteres.
3. Acesso anonimo de desenvolvimento embutido nas rotas de tickets.
 - Antes: qualquer chamada sem token em `development` herdava usuario demo.
 - Correcao: comportamento agora depende de `ALLOW\_DEV\_ANONYMOUS\_ACCESS=false` por padrao.
4. Escalada de privilegio por auto-cadastro.
 - Antes: o payload de registro aceitava `role` arbitrario, inclusive `admin`.
 - Correcao: o cadastro publico sempre normaliza a role para `technician`.
5. Endpoints do agente sem autenticao.
 - Antes: `/agent/chat` e `/agent/tickets/analyze` eram publicos.
 - Correcao: autenticao JWT obrigatoria nas rotas do agente.
6. Ingestao de Intel sem protecao efetiva.
 - Antes: `intel\_require\_auth` default desligado e `ingest/once` dependia da mesma configuracao frouxa.
 - Correcao: `INTEL\_REQUIRE\_AUTH=true` por padrao e `/intel/ingest/once` agora exige autenticao.
7. Comparacao de segredo interno do n8n vulneravel a comparacao simples.
 - Antes: comparacao direta de string.
 - Correcao: uso de comparacao em tempo constante (`hmac.compare\_digest`).

FPConnect - Auditoria de Seguranca

Gerado em 05/04/2026 02:13:15

8. Parametros sem limites explicitos.

- Antes: listagens aceitavam limites arbitrarios no runtime.
- Correcao: uso de `Query` com limites e validacoes.

9. Ausencia de headers defensivos.

- Correcao: adicionados `X-Content-Type-Options`, `X-Frame-Options`, `Referrer-Policy`, `Permissions-Policy`, `Cross-Origin-Resource-Policy` e `HSTS` em producao.

Web

1. Dependencias vulneraveis.

- Correcao: `next` atualizado para `15.5.14`, `jspdf` atualizado para `4.2.1`, dependencias transitivas saneadas com `npm audit fix`.
- Resultado: `npm audit` do web ficou com zero vulnerabilidades.

2. Exportacao via `xlsx`.

- Risco: superficie historica de prototype pollution/ReDoS.
- Correcao: remocao do uso de `xlsx` e substituicao por exportacao CSV nativa.

3. Armazenamento de token no `localStorage`.

- Correcao: o cliente auxiliar passou a usar `sessionStorage`, reduzindo persistencia indevida do token no browser.

4. URL remota insegura.

- Correcao: cliente web agora bloqueia chamadas para APIs remotas sem HTTPS.

5. Endpoint de narracao expondo detalhes internos.

- Correcao: validacao de parametro, logs internos controlados e mensagens publicas genericas.

6. Headers de seguranca ausentes na camada Next.js.

- Correcao: adicionados headers defensivos em `next.config.js`.

Mobile

1. Dependencias vulneraveis.

- Correcao: `npm audit fix` executado.
- Resultado: `npm audit` do mobile ficou com zero vulnerabilidades.

2. Cliente remoto sem endurecimento minimo.

- Antes: aceitava qualquer `EXPO\_PUBLIC\_API\_URL`, inclusive remota sem HTTPS.
- Correcao: o app so usa API remota se for `https://` ou localhost.

3. Headers de autenticacao inexistentes.

- Correcao: suporte a `EXPO\_PUBLIC\_API\_TOKEN` para chamadas autenticadas quando configurado.

Validacoes executadas

1. `python -m pytest` em `apps/api`

- Resultado: 7 testes aprovados.

2. `npm audit --json` em `apps/web`

- Resultado: zero vulnerabilidades.

3. `npm test` em `apps/web`

- Resultado: testes aprovados.

4. `npm run build` em `apps/web`

- Resultado: build concluido com sucesso.

5. `npm audit --json` em `apps/mobile`

- Resultado: zero vulnerabilidades.

FPConnect - Auditoria de Seguranca

Gerado em 05/04/2026 02:13:15

Limitacoes e riscos residuais

1. A auditoria automatizada de dependencias Python via `pip-audit` nao foi concluida por limitacao local de build do `psycpg2-binary` (ausencia de `pg\_config` no ambiente de auditoria temporario). O backend, no entanto, foi endurecido no codigo e validado com testes.
2. A suite de testes do mobile continua falhando por problemas pre-existentes de mocks/componentes e timers, nao introduzidos por esta remediacao. Isso deve ser tratado em uma etapa separada de qualidade.
3. O build web ainda exhibe warnings de lint antigos sobre `any` e simbolos nao utilizados fora do escopo desta remediacao de seguranca.

Arquivos principais alterados

- `apps/api/app/core/config.py`
- `apps/api/app/core/security.py`
- `apps/api/app/main.py`
- `apps/api/app/api/routes/auth.py`
- `apps/api/app/api/routes/tickets.py`
- `apps/api/app/api/routes/intel.py`
- `apps/api/app/api/routes/agent.py`
- `apps/api/app/api/routes/n8n.py`
- `apps/api/app/schemas/user.py`
- `apps/api/tests/test\_agent\_api.py`
- `apps/mobile/app/tickets.tsx`
- `apps/web/next.config.js`
- `apps/web/package.json`
- `apps/web/src/services/api.ts`
- `apps/web/src/services/apiClient.ts`
- `apps/web/src/app/api/demo-narration/route.ts`
- `apps/web/src/app/metrics/page.tsx`
- `apps/web/src/app/history/page.tsx`
- `apps/web/src/app/demo-recursos/page.tsx`
- `apps/web/src/app/agent/page.tsx`
- `apps/web/src/utils/downloadCsv.ts`

Conclusao

O sistema ficou significativamente mais seguro do que o estado inicial, especialmente no que diz respeito a autenticao, autorizacao, configuracao de producao e dependencias JS expostas. O backend deixou de aceitar varios fluxos inseguros por padrao, o web e o mobile ficaram com `npm audit` limpo, e o material deste relatorio foi arquivado em Markdown e PDF.